What is Amazon Cognito?

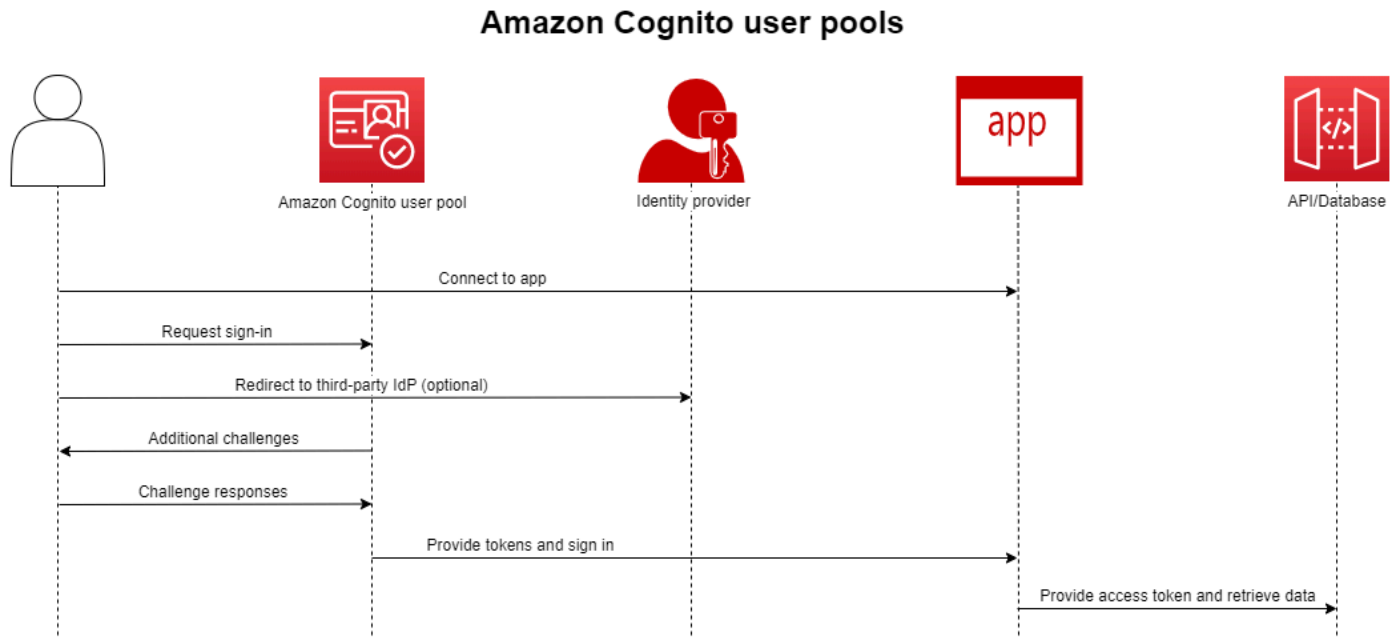
Amazon Cognito is an identity platform for web and mobile apps. It's a user directory, an authentication server, and an authorization service for OAuth 2.0 access tokens and AWS credentials. With Amazon Cognito, you can authenticate and authorize users from the built-in user directory, from your enterprise directory, and from consumer identity providers like Google and Facebook.

Topics

- User pools
- Identity pools
- Features of Amazon Cognito
- Amazon Cognito user pools and identity pools comparison
- Getting started with Amazon Cognito
- Regional availability
- Pricing for Amazon Cognito
- Common Amazon Cognito terms and concepts
- Getting started with AWS

The two components that follow make up Amazon Cognito. They operate independently or in tandem, based on your access needs for your users.

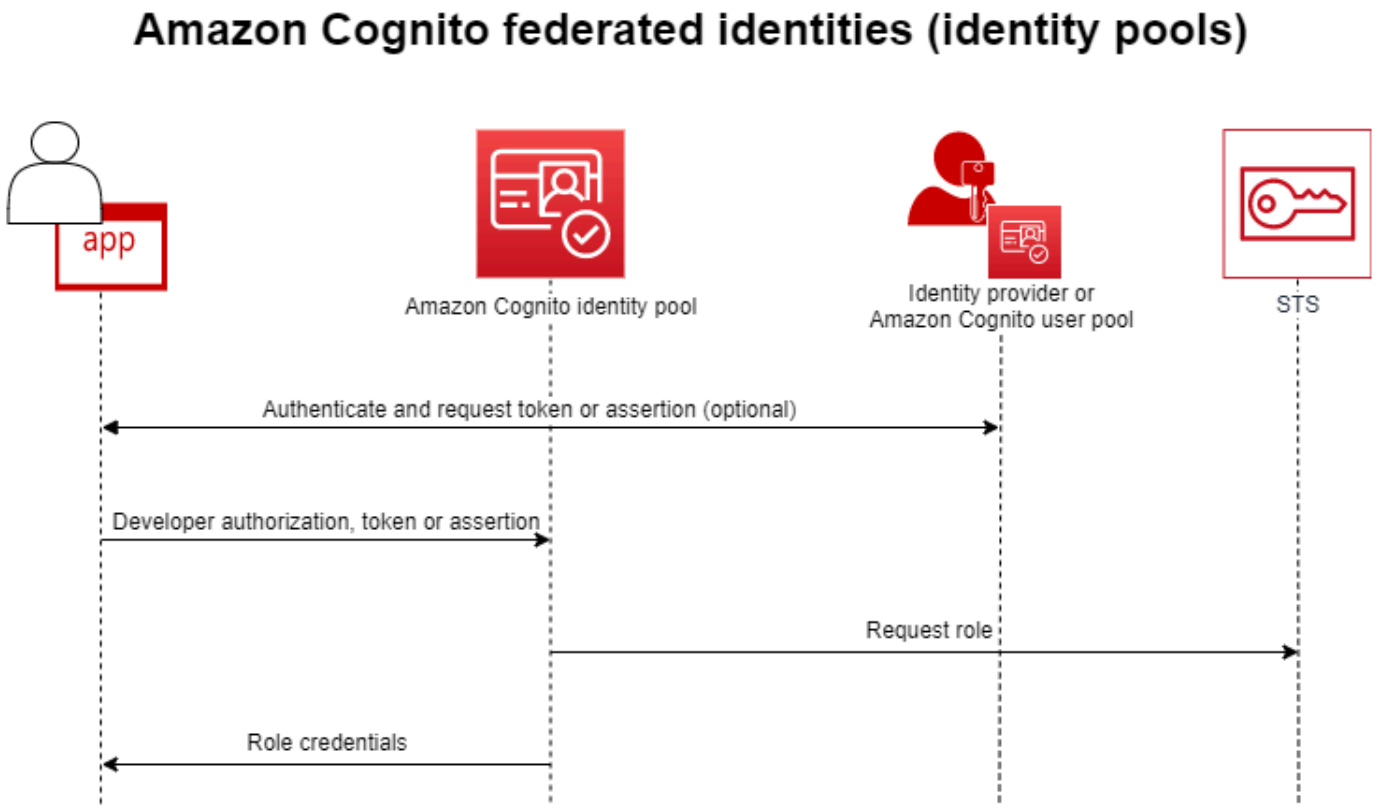
User pools



Create a user pool when you want to authenticate and authorize users to your app or API. User pools are a user directory with both self-service and administrator-driven user creation, management, and authentication. Your user pool can be an independent directory and OIDC identity provider (IdP), and an intermediate service provider (SP) to third-party providers of workforce and customer identities. You can provide single sign-on (SSO) in your app for your organization's workforce identities in SAML 2.0 and OIDC IdPs with user pools. You can also provide SSO in your app for your organization's customer identities in the public OAuth 2.0 identity stores Amazon, Google, Apple and Facebook. For more information about customer identity and access management (CIAM), see What is CIAM?.

User pools don’t require integration with an identity pool. From a user pool, you can issue authenticated JSON web tokens (JWTs) directly to an app, a web server, or an API.

Identity pools



Set up an Amazon Cognito identity pool when you want to authorize authenticated or anonymous users to access your AWS resources. An identity pool issues AWS credentials for your app to serve resources to users. You can authenticate users with a trusted identity provider, like a user pool or a SAML 2.0 service. It can also optionally issue credentials for guest users. Identity pools use both role-based and attribute-based access control to manage your users' authorization to access your AWS resources.

Identity pools don't require integration with a user pool. An identity pool can accept authenticated claims directly from both workforce and consumer identity providers.

An Amazon Cognito user pool and identity pool used together

In the diagram that begins this topic, you use Amazon Cognito to authenticate your user and then grant them access to an AWS service.

1. Your app user signs in through a user pool and receives OAuth 2.0 tokens.

2. Your app exchanges a user pool token with an identity pool for temporary AWS credentials that you can use with AWS APIs and the AWS Command Line Interface (AWS CLI).
3. Your app assigns the credentials session to your user, and delivers authorized access to AWS services like Amazon S3 and Amazon DynamoDB.

For more examples that use identity pools and user pools, see Common Amazon Cognito scenarios.

In Amazon Cognito, the *security of the cloud* obligation of the shared responsibility model is compliant with SOC 1-3, PCI DSS, ISO 27001, and is HIPAA-BAA eligible. You can design your *security in the cloud* in Amazon Cognito to be compliant with SOC1-3, ISO 27001, and HIPAA-BAA, but not PCI DSS. For more information, see AWS services in scope. See also Regional data considerations.

Features of Amazon Cognito

User pools

An Amazon Cognito user pool is a user directory. With a user pool, your users can sign in to your web or mobile app through Amazon Cognito, or federate through a third-party IdP. Federated and local users have a user profile in your user pool.

Local users are those who signed up or you created directly in your user pool. You can manage and customize these user profiles in the AWS Management Console, an AWS SDK, or the AWS Command Line Interface (AWS CLI).

Amazon Cognito user pools accept tokens and assertions from third-party IdPs, and collect the user attributes into a JWT that it issues to your app. You can standardize your app on one set of JWTs while Amazon Cognito handles the interactions with IdPs, mapping their claims to a central token format.

An Amazon Cognito user pool can be a standalone IdP. Amazon Cognito draws from the OpenID Connect (OIDC) standard to generate JWTs for authentication and authorization. When you sign in local users, your user pool is authoritative for those users. You have access to the following features when you authenticate local users.

- Implement your own web front-end that calls the Amazon Cognito user pools API to authenticate, authorize, and manage your users.

Unauthenticated access	Issue limited-access web identity credentials from AWS STS without authentication	✓
Role-based access control	Choose an IAM role for your authenticated user based on their claims, and configure your role trust to limit access to web identity users	✓
Attribute-based access control	Transform user claims into principal tags for your AWS STS temporary session, and use IAM policies to filter resource access based on principal tags	✓

[1] Feature is not available to federated users.

Getting started with Amazon Cognito

For example user pool applications, see Getting started with user pools.

For an introduction to identity pools, see Getting started with Amazon Cognito identity pools.

For links to guided setup experiences with user pools and identity pools, see Guided setup options for Amazon Cognito.

To get started with an AWS SDK, see AWS Developer Tools. For developer resources specific to Amazon Cognito, see Amazon Cognito developer resources.

To use Amazon Cognito, you need an AWS account. For more information, see Getting started with AWS.

Regional availability

Amazon Cognito is available in multiple AWS Regions worldwide. In each Region, Amazon Cognito is distributed across multiple Availability Zones. These Availability Zones are physically isolated from each other, but are united by private, low-latency, high-throughput, and highly redundant network connections. These Availability Zones enable AWS to provide services, including Amazon Cognito, with very high levels of availability and redundancy, while also minimizing latency.

To see if Amazon Cognito is currently available in any AWS Region, see AWS Services by Region.

To learn about regional API service endpoints, see AWS regions and endpoints in the *Amazon Web Services General Reference*.

To learn more about the number of Availability Zones that are available in each Region, see AWS global infrastructure.

Pricing for Amazon Cognito

For information about Amazon Cognito pricing, see Amazon Cognito pricing.

Common Amazon Cognito terms and concepts

Amazon Cognito provides credentials for web and mobile apps. It draws from and builds on terms that are common in *identity and access management*. Many guides to universal identity and access terms are available. Some examples are:

- Terminology in the IDPro Body of Knowledge
- AWS Identity Services
- Glossary from NIST CSRC

The following lists describe terms that are unique to Amazon Cognito or have a specific context in Amazon Cognito.

Topics

- General
- User pools
- Identity pools

General

The terms in this list aren't specific to Amazon Cognito and are widely recognized among identity and access management practitioners. The following isn't an exhaustive list of terms, but a guide to their specific Amazon Cognito context in this guide.

Access token

A JSON web token (JWT) that contains information about an entity's authorization to access information systems.

App, application

Typically, a mobile application. In this guide, *app* is often a shorthand for a web application or mobile app that connects to Amazon Cognito.

Attribute-based access control (ABAC)

A model where an app determines access to resources based on the properties of a user, like their job title or department. Amazon Cognito tools to enforce ABAC include ID tokens in user pools and principal tags in identity pools.

Authentication

The process of establishing an authentic identity for the purpose of access to an information system. Amazon Cognito accepts proof of authentication from third-party identity providers, and also serves as a provider of authentication to software applications.

Authorization

The process of granting permissions to a resource. User pool access tokens contain information that applications can use to permit users and systems to access resources.

Authorization server

An OAuth or OpenID Connect (OIDC) system that generates JSON web tokens. The Amazon Cognito user pools managed authorization server is the authorization-server component of the two authentication and authorization methods in user pools. User pools also support API challenge-response flows in SDK authentication.

Confidential app, server-side app

An application that users connect to remotely, with code on an application server and access to secrets. This is typically a web application.

Identity provider (IdP)

A service that stores and verifies user identities. Amazon Cognito can request authentication from external providers and be an IdP to apps.

JSON web token (JWT)

A JSON-formatted document that contains claims about an authenticated user. ID tokens authenticate users, access tokens authorize users, and refresh tokens update credentials. Amazon Cognito receives tokens from external providers and issues tokens to apps or AWS STS.

Machine-to-machine (M2M) authorization

The process of authorizing requests to API endpoints for non-user-interactive machine entities, like a webserver application tier. User pools serve M2M authorization in client-credentials grants with OAuth 2.0 scopes in access tokens.

Multi-factor authentication (MFA)

The requirement that users provide additional authentication after providing their username and password. Amazon Cognito user pools have MFA features for local users.

OAuth 2.0 (social) provider

An IdP to a user pool or identity pool that provides JWT access and refresh tokens. Amazon Cognito user pools automate interactions with social providers after users authenticate.

OpenID Connect (OIDC) provider

An IdP to a user pool or identity pool that extends the OAuth specification to provide ID tokens. Amazon Cognito user pools automate interactions with OIDC providers after users authenticate.

Passkey, WebAuthn

A form of authentication where cryptographic keys, or passkeys, on a user's device provides their proof of authentication. Users verify that they are present with biometric or PIN code mechanisms in a hardware or software authenticator. Passkeys are phishing-resistent and bound to specific websites/apps, offering a secure passwordless experience. Amazon Cognito user pools support sign-in with passkeys.

Passwordless

A form of authentication where a user doesn't have to enter a password. Methods of passwordless sign-in include one-time passwords (OTPs) sent to email addresses and phone numbers, and passkeys. Amazon Cognito user pools support sign-in with OTPs and passkeys.

Public app

An application that is self-contained on a device, with code stored locally and no access to secrets. This is typically a mobile app.

Resource server

An API with access control. Amazon Cognito user pools also use *resource server* to describe the component that defines the configuration for interacting with an API.

Role-based access control (RBAC)

A model that grants access based on a user's functional designation. Amazon Cognito identity pools implement RBAC with differentiation between IAM roles.

Service provider (SP), relying party (RP)

An application that relies on an IdP to assert that users are trustworthy. Amazon Cognito acts as an SP to external IdPs, and as an IdP to app-based SPs.

SAML provider

An IdP to a user pool or identity pool that generates digitally signed assertion documents that your user passes to Amazon Cognito.

Universally Unique Identifier (UUID)

A 128-bit label that is applied to an object. Amazon Cognito UUIDs are unique per user pool or identity pool, but don't conform to a specific UUID format.

User directory

A collection of users and their attributes that serves that information to other systems. Amazon Cognito user pools are user directories, and also tools for consolidation of users from external user directories.

User pools

When you see the terms in the following list in this guide, they refer to a specific feature or configuration of user pools.

Adaptive authentication

A feature of advanced security that detects potential malicious activity and applies additional security to user profiles.

App client

A component that defines the settings for a user pool as an IdP to one app.

Callback URL, redirect URI, return URL

A setting in an app client and a parameter in requests to the user pool's authorization server. The callback URL is the initial destination for authenticated users in your app.

Choice-based authentication

A form of API authentication with users pools where each user has a set of choices for sign-in available to them. Their choices might include username and password with or without MFA, passkey sign-in, or passwordless sign-in with email or SMS message one-time passwords. Your application can shape the choice process for users by requesting a list of authentication options or by declaring a preferred option.

Compare with client-based authentication.

Client-based authentication

A form of authentication with the user pools API and application back ends built with AWS SDKs. In declarative authentication, your application determines independently the login type that a user should perform and requests that type up front.

Compare with choice-based authentication.

Compromised credentials

A feature of advanced security that detects user passwords that attackers might know, and applies additional security to user profiles.

Confirmation

The process that determines that the prerequisites have been met to permit a new user to sign in. Confirmation is typically done through email address or phone number verification.

Custom authentication

An extension of authentication processes with Lambda triggers that define additional user challenges and responses.

Device authentication

An authentication process that replaces MFA with sign-in that uses the ID of a trusted device.

Domain, user pool domain

A web domain that hosts your managed login pages in AWS. You can set up DNS in a domain that you own or use an identifying subdomain prefix in a domain that AWS owns.

Essentials plan

The feature plan with the latest developments in user pools. The Essentials plan doesn't include the automated-learning security features in the Plus plan.

External provider, third-party provider

An IdP that has a trust relationship with a user pool. User pools serve as an intermediate entity between external providers and your application, managing authentication processes with SAML 2.0, OIDC, and social providers. User pools consolidate external-provider authentication outcomes into a single IdP so that your applications can process many users with a single OIDC relying-party library.

Feature plan

The group of features that you can select for a user pool. Feature plans have differing costs in your AWS bill. New user pools default to the Essentials plan.

Current plans

- Lite plan
- Essentials plan
- Plus plan

Federated user, external user

A user in a user pool who was authenticated by an external provider.

Hosted UI (classic), hosted UI pages

The early version of the authentication front end, relying party, and identity provider services on your user pool domain. The hosted UI has a basic set of features and a simplified look and feel. You can apply Hosted UI branding with the upload of a logo-image file and a file with a predetermined set of CSS styles. Compare to managed login.

Lambda trigger

A function in AWS Lambda that a user pool can automatically invoke at key points in user authentication processes. You can use Lambda triggers to customize authentication outcomes.

Local user

A user profile in the user pool user directory that wasn't created by authentication with an external provider.

Linked user

A user from an external provider whose identity is merged with a local user.

Lite plan

The feature plan with the features that originally launched with user pools. The Lite plan doesn't include the new features in the Essentials plan or the automated-learning security features in the Plus plan.

Managed authorization server, hosted UI authorization server, authorization server

A component of managed login that hosts services for interaction with IdPs and apps on your user pool domain. The hosted UI differs from managed login in the user-interactive features it offers, but has the same authorization-server capabilities.

Managed login, managed login pages

A set of webpages on your user pool domain that host services for user authentication. These services include functions for operating as an IdP, a relying party for third-party IdPs, and a server of a user-interactive authentication UI. When you set up a domain for your user pool, Amazon Cognito brings all managed login pages online.

Your application import OIDC libraries that invoke users' browsers and direct them to the managed login UI for sign-up, sign-in, password management, and other authentication operations. After authentication, the OIDC libraries can process the outcome of the authentication request.

Managed login authentication

Sign-in with the services on your user pool domain, done with user-interactive browser pages or HTTPS API requests. Applications handle managed login authentication with OpenID Connect (OIDC) libraries. This process includes sign-in with external providers, local-user sign-in with

interactive managed login pages, and M2M authorization. Authentication with the classic hosted UI also fall under this term.

Compare to AWS SDK authentication.

Plus plan

The feature plan with the latest developments and advanced security features in user pools.

SDK authentication, AWS SDK authentication

A set of authentication and authorization API operations that you can add to your application back end with an AWS SDK. This authentication model requires your own custom-built login mechanism. The API can sign in local users and linked users.

Compare to managed login authentication.

Threat protection, advanced security features

In user pools, threat protection refers to technologies that are designed to mitigate threats to your authentication and authorization mechanisms. Adaptive authentication, compromised-credentials detection, and IP address blocklists are under the category of threat protection.

Token customization

The outcome of a pre token generation Lambda trigger that modifies a user's ID or access token at runtime.

User pool, Amazon Cognito identity provider, `cognito-idp`, Amazon Cognito user pools

An AWS resource with authentication and authorization services for applications that work with OIDC IdPs.

Verification

The process of confirming that a user owns an email address or phone number. A user pool sends a code to a user who has entered a new email address or phone number. When they submit the code to Amazon Cognito, they verify their ownership of the message destination and can receive additional messages from the user pool. Also, see confirmation.

User profile, user account

An entry for a user in the user directory. All users, including those from third-party IdPs, have a profile in their user pool.

Identity pools

When you see the terms in the following list in this guide, they refer to a specific feature or configuration of identity pools.

Attributes for access control

An implementation of attribute-based access control in identity pools. Identity pools apply user attributes as tags to user credentials.

Basic (classic) authentication

An authentication process where you can customize the request for user credentials.

Developer authenticated identities

An authentication process that authorizes identity pool user credentials with developer credentials.

Developer credentials

The IAM API keys of an identity pool administrator.

Enhanced authentication

An authentication flow that selects an IAM role and applies principal tags according to the logic that you define in your identity pool.

Identity

A UUID that links an app user and their user credentials to their profile in an external user directory that has a trust relationship with an identity pool.

Identity pool, Amazon Cognito federated identities, Amazon Cognito identity, `cognito-identity`

An AWS resource with authentication and authorization services for applications that use temporary AWS credentials.

Unauthenticated identity

A user who has not signed in with an identity pool IdP. You can permit users to generate limited user credentials for a single IAM role before they authentication.

User credentials

Temporary AWS API keys that users receive after identity pool authentication.

Getting started with AWS

Before you start working with Amazon Cognito, set yourself up with some required AWS resources. If you can already sign in to an AWS account, you can skip this section. Continue reading if you are looking for information about signing up and signing in with AWS credentials. After you have credentials with sufficient AWS Identity and Access Management (IAM) permissions, you can get started with user pools and identity pools.

Sign up for an AWS account

If you do not have an AWS account, complete the following steps to create one.

To sign up for an AWS account

1. Open https://portal.aws.amazon.com/billing/signup.
2. Follow the online instructions.

   Part of the sign-up procedure involves receiving a phone call or text message and entering a verification code on the phone keypad.

   When you sign up for an AWS account, an *AWS account root user* is created. The root user has access to all AWS services and resources in the account. As a security best practice, assign administrative access to a user, and use only the root user to perform tasks that require root user access.

AWS sends you a confirmation email after the sign-up process is complete. At any time, you can view your current account activity and manage your account by going to https://aws.amazon.com/ and choosing **My Account**.

Create a user with administrative access

After you sign up for an AWS account, secure your AWS account root user, enable AWS IAM Identity Center, and create an administrative user so that you don't use the root user for everyday tasks.

Secure your AWS account root user

1. Sign in to the AWS Management Console as the account owner by choosing **Root user** and entering your AWS account email address. On the next page, enter your password.

For help signing in by using root user, see Signing in as the root user in the *AWS Sign-In User Guide*.

2. Turn on multi-factor authentication (MFA) for your root user.

   For instructions, see Enable a virtual MFA device for your AWS account root user (console) in the *IAM User Guide*.

Create a user with administrative access

1. Enable IAM Identity Center.

   For instructions, see Enabling AWS IAM Identity Center in the *AWS IAM Identity Center User Guide*.

2. In IAM Identity Center, grant administrative access to a user.

   For a tutorial about using the IAM Identity Center directory as your identity source, see Configure user access with the default IAM Identity Center directory in the *AWS IAM Identity Center User Guide*.

Sign in as the user with administrative access

- To sign in with your IAM Identity Center user, use the sign-in URL that was sent to your email address when you created the IAM Identity Center user.

  For help signing in using an IAM Identity Center user, see Signing in to the AWS access portal in the *AWS Sign-In User Guide*.

Assign access to additional users

1. In IAM Identity Center, create a permission set that follows the best practice of applying least-privilege permissions.

   For instructions, see Create a permission set in the *AWS IAM Identity Center User Guide*.

2. Assign users to a group, and then assign single sign-on access to the group.

   For instructions, see Add groups in the *AWS IAM Identity Center User Guide*.